What is SSO, and how to integrate with Drupal 10 or 11?

SSO (Single Sign-On) is a centralized authentication method that allows users to log in once and access multiple systems or applications **without re-entering credentials**.

For **Drupal 10/11**, integrating SSO can significantly improve **user experience**, **security**, and **centralized access control**, especially in enterprise or government environments.

🔐 What Is SSO?

Single Sign-On (SSO) enables users to authenticate via a **central identity provider (IdP)**, such as:

- **Azure AD**
- **Okta**
- **Google Workspace**
- **Auth0**
- **Keycloak**
- **Shibboleth**
- **LDAP / Active Directory**

These IdPs use standardized protocols like:

Protocol	Description
SAML 2.0	XML-based, common in enterprise SSO
OAuth2	Token-based auth, often used with APIs
OpenID Connect (OIDC)	Layer on OAuth2, used in modern apps
LDAP	Directory-based authentication

🧩 How to Integrate SSO in Drupal 10/11

Drupal supports SSO via **contributed modules** and sometimes **custom integrations**, depending on your IdP and protocol.

🔧 Option 1: SAML 2.0 SSO Integration

✅ **Recommended Module: [SimpleSAMLphp Auth]**

🔌 **Prerequisites:**

- SimpleSAMLphp installed (in /vendor or separate directory)
- Drupal module: simplesamlphp_auth

🔨 **Setup Steps:**

Install SimpleSAMLphp

composer require simplesamlphp/simplesamlphp

1. **Install Drupal module**
   composer require drupal/simplesamlphp_auth

   drush en simplesamlphp_auth -y

2. **Configure SimpleSAMLphp** (usually at /simplesaml):
   - Add your IdP metadata
   - Set SP (Service Provider) metadata
3. **Configure the Drupal module**
   At /admin/config/people/simplesamlphp_auth, set:
   - Enable SAML authentication
   - Map SAML attributes to Drupal fields (e.g., mail, uid)
   - Optionally auto-provision users
4. **Set default login behavior**
   - Redirect /user/login to IdP
   - Allow fallback login for admins (if needed)

🔧 **Option 2: OAuth2 / OpenID Connect (OIDC)**

✅ **Recommended Module: [OAuth/OpenID Connect]**

Common IdPs: Azure AD, Google, Keycloak, Auth0, Okta

🔨 **Setup Steps:**

Install the module

composer require drupal/openid_connect

drush en openid_connect -y

1. **Configure Provider**
   At /admin/config/people/openid-connect, add a new provider.
   Example for Azure AD:
   $config['openid_connect.client.azure'] = [

```
  'client_id' => 'YOUR_CLIENT_ID',
  'client_secret' => 'YOUR_CLIENT_SECRET',
  'authorization_endpoint' =>
'https://login.microsoftonline.com/YOUR_TENANT_ID/oauth2/v2.0/authorize',
  'token_endpoint' =>
'https://login.microsoftonline.com/YOUR_TENANT_ID/oauth2/v2.0/token',
  'userinfo_endpoint' => 'https://graph.microsoft.com/oidc/userinfo',
  'scopes' => ['openid', 'email', 'profile'],
];
```

2. **Redirect URIs**
   Register your site's redirect URI in your IdP:
   https://your-site.com/openid-connect/azure/callback
3. **User Mapping**
   - Map user claims (e.g., email) to Drupal accounts
   - Auto-provision users if needed

🔧 Option 3: LDAP or Active Directory

✅ Recommended Module: [LDAP]

Setup Steps:

Install the module

```
composer require drupal/ldap
drush en ldap -y
```

1. **Configure LDAP server connection**
   - Host, port, base DN, bind DN
   - Test connection
2. **Configure Authentication**
   - Bind user credentials via LDAP login
   - Sync LDAP attributes (mail, name, roles)

🔄 Auto-Provisioning vs. Manual Account Linking

Method	Description
Auto-provisioning	Create Drupal users upon first login via SSO
Manual linking	Require users to already exist in Drupal
Hybrid	Admins approve new SSO users before activation

📄 Common Use Cases

Scenario	Recommended Protocol/Module
Enterprise (Okta, Azure AD)	OpenID Connect / SAML
Government or University (Shibboleth)	SAML + SimpleSAMLphp
Internal staff (Active Directory)	LDAP
Developer portals (Apigee, etc.)	OIDC / OAuth2

🔐 Security Best Practices

- Enable **HTTPS** on all SSO flows.
- Limit fallback login access to admins only.
- Audit **user role mappings** and permissions after login.
- Periodically test **logout** and **SSO session expiration** behavior.

🧪 Testing SSO

- Use incognito/private browser windows to test login behavior.
- Confirm new user creation (if enabled).
- Confirm existing user mapping works as expected.
- Test login redirection, logout, and permission sync.

✅ Summary: Which Module Should I Use?

Protocol	Module	Drupal 10/11 Compatible?	Notes
SAML 2.0	simplesamlphp_auth	✅	Widely used in gov/edu
OpenID Connect	openid_connect	✅	Works with Azure, Google, Okta
OAuth2	simple_oauth, oauth2_client	✅	For API clients, not user login
LDAP	ldap	✅	Connects to Active Directory

⚙️ Want a working example?

I can provide:

- A working openid_connect config for Azure AD, Google, or Keycloak
- A sample simplesamlphp config folder for SAML setup
- A checklist for production-ready SSO setup

Let me know your IdP or platform, and I'll tailor the setup to it.

How to integrate SSO with Drupal using SAML

Integrating **SSO with Drupal using SAML** is a common requirement for enterprise or university systems that use Identity Providers (IdPs) like **Azure AD**, **Okta**, **Google Workspace**, **Shibboleth**, or **ADFS**.

The most widely used method for this is through the **SimpleSAMLphp** authentication library and the **Drupal simplesamlphp_auth module**.

🧩 Overview: What You Need

🧠 Key Concepts

Term	Meaning
IdP	Identity Provider (e.g., Azure AD, Okta, Shibboleth)
SP	Service Provider – your **Drupal site**
SAML	Protocol for exchanging authentication/authorization data securely
SSO	Single Sign-On – log in once to access many apps
SimpleSAMLphp	A lightweight SAML PHP toolkit used to handle SAML assertions in Drupal

---

✅ Step-by-Step Guide: Drupal + SAML SSO

---

1. Install and Configure SimpleSAMLphp

📦 Option A: Use Composer

```
composer require simplesamlphp/simplesamlphp
```

It will be installed in vendor/simplesamlphp/simplesamlphp.

📦 Option B: Download Standalone

Download and place SimpleSAMLphp in a directory like /opt/simplesamlphp or /var/simplesaml.

Set web access to: http(s)://your-site.com/simplesaml/

---

2. Configure SimpleSAMLphp

Go to the config folder (e.g., vendor/simplesamlphp/simplesamlphp/config/).

Edit config/config.php:

```
'baseurlpath' => '/simplesaml/',
'auth.adminpassword' => 'YourAdminPassword',
```

Define your Service Provider (SP) in metadata/saml20-sp-remote.php or config/authsources.php

Example SP definition in authsources.php:

```
'default-sp' => [
    'saml:SP',
    'idp' => 'https://idp.example.com/sso',
    'entityID' =>
'https://your-drupal-site.com/simplesaml/module.php/saml/sp/metadata.php/default-sp',
    'privatekey' => 'your.key',
    'certificate' => 'your.crt',
],
```

---

3. Install Drupal SAML Module

✅ **Use the SimpleSAMLphp Auth module**

```
composer require drupal/simplesamlphp_auth
drush en simplesamlphp_auth -y
```

---

4. Connect Drupal to SimpleSAMLphp

At /admin/config/people/simplesamlphp_auth, set:

Setting	Value
Enable authentication via SAML	✅
Path to SimpleSAMLphp library	e.g., /vendor/simplesamlphp/simplesamlphp or /opt/simplesamlphp
Authsource name	default-sp (or the key you used in authsources.php)
Automatically create users?	✅ or ☐ depending on policy
Map email / name ID	e.g., mail, uid, eduPersonPrincipalName

---

5. Configure the Identity Provider (IdP)

Provide your IdP admin with your SP **metadata**, found at:

https://your-site.com/simplesaml/module.php/saml/sp/metadata.php/default-sp

They will:

- Register your Drupal site as a SAML SP
- Provide IdP metadata or SSO URL + certificate

Place their metadata in metadata/saml20-idp-remote.php or upload it via SimpleSAMLphp UI.

---

6. Test SAML Login

1. Go to /simplesaml/ to access the SimpleSAMLphp admin UI.
2. Test SP metadata and connection.
3. Visit /user/login on your Drupal site – it should redirect to the IdP and back after successful login.

---

7. Optional Configurations

🔓 Fallback Login

To prevent lockout:

- Enable /user/login for admin users via Drupal local login.
- Or enable a separate admin login path.

🧪 User Mapping

You can map SAML attributes to Drupal fields under simplesamlphp_auth settings:

Drupal Field	SAML Attribute
Email	mail
Username	uid or name

👩‍🔧 Role Mapping

Use modules like:

- saml_sp or
- ldap_authorization (if integrating with LDAP too)

🛡️ Security Best Practices

- Use **HTTPS** everywhere (especially on /simplesaml paths).
- Set up **logout hooks** to destroy both Drupal and IdP sessions.
- Monitor session expiration and auto-logout.

- **Restrict user provisioning** if only specific users should access Drupal.

🧪 Testing Tips

- Use **Incognito Mode** to test SAML flows independently.
- Check:
  - User creation or mapping
  - Role assignment (if applicable)
  - Login/logout behaviors
- Debug logs:
  - Drupal logs: /admin/reports/dblog
  - SimpleSAMLphp logs: /var/log/simplesamlphp.log (or in log/ folder)

✅ Summary: What's Needed

Component	Purpose
SimpleSAMLphp	SAML authentication handler
Drupal simplesamlphp_auth module	Connects Drupal to SimpleSAMLphp
IdP Metadata	Provided by your SAML Identity Provider
SP Metadata	Provided to your IdP from Drupal/SimpleSAMLphp
User field mappings	Tells Drupal how to use SAML data

👀 Want a working setup?

I can send you:

- A sample authsources.php file
- A ready-to-import IdP metadata file
- A sample SAML test user flow

Let me know:

- What IdP you're using (e.g., Azure AD, Okta, Shibboleth)?
- Is your Drupal hosted on-prem or cloud (Acquia, Pantheon, etc.)?

I'll tailor the config for your case.

What is Okta?

Okta is a **cloud-based Identity and Access Management (IAM) platform** that helps organizations securely manage and streamline:

- **User authentication**
- **Single Sign-On (SSO)**
- **Multi-Factor Authentication (MFA)**
- **User lifecycle management**
- **API access control**

It's widely used to centralize **user identity** and control access to applications — both internal (e.g., company portals, intranet) and external (e.g., customer-facing web apps).

🔐 What Can Okta Do?

Feature	Description
✅ **SSO (Single Sign-On)**	One login for all connected apps
🔒 **MFA**	Enforce 2FA via SMS, apps, or biometric factors
🔗 **OAuth2 / OIDC / SAML**	Supports standard authentication protocols
👥 **User & Group Management**	Centralized directory or integration with AD/LDAP
📚 **Directory Services**	Acts as a cloud directory or integrates with Microsoft AD or LDAP
🚪 **App Access Management**	Controls who can access what, with detailed policies
🔌 **Integrations**	7,000+ prebuilt integrations (e.g., Salesforce, Google, Drupal, etc.)
☁️ **Cloud-native**	No on-premise infrastructure required

🏢 Who Uses Okta?

- Enterprises looking to simplify **internal IT access**
- SaaS applications adding **secure login options** for users
- Dev teams securing APIs or customer portals
- Organizations replacing legacy authentication systems

🌐 Okta in Action (Real-World Example)

Imagine your company uses:

- Salesforce (CRM)
- Office 365 (Email)
- A custom Drupal 10 developer portal

Instead of logging into each app separately, employees:

1. Sign into Okta once via SSO.
2. Get access to all authorized apps.
3. MFA may be enforced depending on context (e.g., location, risk).

When a user leaves the company, revoking their Okta account removes access from all connected systems.

🤝 Okta Integration with Drupal

You can integrate Okta with Drupal for **SSO using**:

Protocol	Drupal Module	Notes
OpenID Connect	`openid_connect`	Easiest modern option
SAML 2.0	`simplesamlphp_auth`	More common in enterprises
OAuth2	`oauth2_client`	Okta can act as OAuth2 provider

Okta acts as the **IdP** (Identity Provider), and Drupal is the **SP** (Service Provider).

📦 Okta Developer Tools

Okta also provides:

- **Developer accounts**: https://developer.okta.com
- **APIs** to manage users, tokens, apps
- **SDKs** for frontend frameworks (React, Vue, etc.)
- **API Access Management** (OAuth2 scopes, custom policies)

🧪 Want to Try It?

You can sign up for a **free Okta Developer Account**:
👉 https://developer.okta.com/signup/

Then:

- Create an OIDC or SAML application
- Set up integration with your Drupal site
- Test SSO login flows

Working Flow of SSO with Drupal

Implementing **Single Sign-On (SSO)** with **Drupal** typically involves integrating an identity provider (IdP) like **Okta**, **Azure AD**, **Google Workspace**, or any **SAML/OAuth2** compatible provider.

Below is a clear working flow of how SSO works with Drupal, including modules and configuration tips.

🔁 High-Level SSO Workflow in Drupal

✅ 1. User accesses a protected page on the Drupal site

- If the user is not logged in, Drupal redirects them to the **Identity Provider (IdP)**.

🔐 2. Drupal redirects to the Identity Provider (IdP)

- This redirection includes metadata like RelayState, Request ID, and the requested authentication method (SAML/OAuth2).
- The IdP handles authentication (e.g., Google login, LDAP, etc.).

👤 3. User logs in on IdP

- If credentials are valid, IdP creates a **token/assertion** (e.g., SAML response or OAuth2 token).
- IdP then redirects the user back to the **Drupal site** with this token.

🔄 4. Drupal validates the token/assertion

- Drupal verifies the signature, issuer, and expiry of the token using public keys or client secrets.
- If valid, it retrieves user attributes (email, name, roles, etc.).

👥 5. User session is created in Drupal

- Drupal creates or maps a user account:
  - If the user exists, it logs them in.
  - If not, Drupal may auto-provision the account (optional).
- The session is established.

🎉 6. User is now logged in and redirected to the requested page

---

🔧 Modules Required in Drupal

Depending on the protocol (SAML or OAuth2), you'll need different modules:

✅ For SAML 2.0

- **SimpleSAMLphp Authentication**
  - Requires installing SimpleSAMLphp library separately.
  - Drupal acts as a **Service Provider (SP)**.

- **SAML SP Lite**
  - Easier to configure, but limited functionality.

✅ For OAuth2 / OpenID Connect

- **OAuth2 / OpenID Connect module**
  - Supports Google, Azure AD, Okta, etc.
  - Supports user info endpoint, auto-provisioning, mapping fields.

🛠️ Configuration Overview

1. Set Up the Identity Provider (IdP)

- Register your Drupal site as a **Service Provider (SP)**.
- Configure redirect URLs:
  - e.g., https://your-drupal-site.com/saml/acs or .../openid-connect/callback

2. Configure the Drupal Module

- Install the required module.
- Provide:
  - Client ID / Secret (OAuth)
  - IdP metadata (SAML)
  - Redirect and logout URLs
  - User attribute mapping (email, name, roles)

3. Test the Flow

- Try accessing a protected page
- Ensure successful redirection to the IdP
- After login, ensure proper user creation or login in Drupal

📁 Example: SAML Flow with SimpleSAMLphp

```
sequenceDiagram
    participant User
    participant Drupal
    participant IdP (e.g., Okta)
    User->>Drupal: Request Protected Page
    Drupal-->>User: Redirect to IdP
    User->>IdP: Login Credentials
    IdP-->>User: SAML Response
    User->>Drupal: SAML Response
    Drupal->>IdP: Validate Token
    IdP-->>Drupal: Validated
    Drupal->>User: Create Session / Redirect
```

🔐 Security Considerations

- Always use HTTPS.
- Rotate secrets/certificates periodically.
- Limit auto-provisioning or restrict to certain domains/groups.
- Enable logout propagation (Single Logout - SLO) if needed.

✅ Summary

Component	Description
Drupal	Acts as SP (Service Provider)
IdP	Authenticates users (Okta, Azure AD, etc.)
Protocol	SAML 2.0 or OAuth2/OpenID Connect
Modules	simplesamlphp_auth, openid_connect, etc.
Key Features	Token validation, user mapping, auto-login/logout

---

Let me know which protocol or provider you're using (e.g., Google, Azure, Okta), and I can help with exact setup steps or example configurations.

Interview Question - Okta, SSO

Here's a list of **interview questions** (with short explanations where needed) related to **Okta**, **SSO (Single Sign-On)**, and **Okta-based login integrations**, particularly useful if you're interviewing for a role that involves **identity and access management (IAM)**, **web app security**, or **SSO implementation** (e.g., with Drupal or other apps):

🔐 General SSO & Identity Management Questions

1. What is Single Sign-On (SSO) and how does it work?

- Explain SSO as an authentication method allowing users to log in once and access multiple systems without re-authenticating.

2. What are the differences between SAML, OAuth2, and OpenID Connect (OIDC)?

- SAML: XML-based, common in enterprise systems.
- OAuth2: Authorization framework, often used in APIs.
- OIDC: Extension of OAuth2 for authentication.

3. What is the role of an Identity Provider (IdP) and a Service Provider (SP) in SSO?

- IdP authenticates the user.
- SP trusts the IdP to vouch for the user's identity.

4. What is a token in the context of SSO and what types of tokens are commonly used?

- Examples: SAML assertions, OAuth access tokens, ID tokens (OIDC).

🔓 Okta-Specific Questions

5. What is Okta and what are its core services?

- Identity as a Service (IDaaS) platform.
- Services: SSO, MFA, Lifecycle Management, API Access Management, Universal Directory.

6. How do you integrate a custom application with Okta for SSO?

- Use either SAML, OAuth2, or OIDC protocols.
- Register app in Okta, configure redirect URIs, client credentials, etc.

7. What is the difference between Okta's SAML and OIDC integrations?

- SAML: XML-based, typically browser-based apps.
- OIDC: Modern, uses JSON tokens (JWT), suitable for APIs and SPAs.

8. How does Okta handle user provisioning and deprovisioning?

- SCIM (System for Cross-domain Identity Management).
- Lifecycle rules (when to activate/deactivate users).

9. What is Okta Universal Directory?

- Central place to manage user attributes, schemas, and mappings from multiple sources (AD, LDAP, apps).

⚙️ Practical Implementation Questions

10. What is an Assertion Consumer Service (ACS) URL?

- The endpoint where the SP (e.g., Drupal) receives the SAML response from Okta.

11. How do you configure Okta as IdP for a Drupal site using SAML?

- Register a new app in Okta (SAML 2.0).
- Provide ACS URL and entity ID from Drupal.
- Set attribute mappings (e.g., email → mail, name → name, etc.).
- Install and configure simplesamlphp_auth in Drupal.

12. What are Okta Groups and how do you use them in SSO?

- Logical user groupings.
- Useful for assigning app access or mapping roles in SP.

13. How would you troubleshoot an SSO login failure in Okta?

- Common causes:
  - Incorrect ACS URL or entity ID
  - Invalid certificate
  - Clock skew issues
  - Attribute mismatch (e.g., missing email)
  - User not assigned to the app in Okta

14. Explain the use of Okta Sign-On Policies and Rules.

- Policies enforce login conditions (e.g., device, location, MFA).
- Rules define specific criteria (e.g., require MFA if user outside network).

🔁 Advanced/Behavioral & Security-Based Questions

15. What is Just-in-Time (JIT) provisioning in Okta?

- Automatically creates users in an app upon first login if they don't exist.

16. What's the difference between ID Token and Access Token in OIDC?

- ID Token: Used for authentication.
- Access Token: Used to access resources (APIs).

17. How do you handle logout with Okta and SSO applications?

- Front-channel logout (redirect user to logout URL).
- Back-channel logout (notify other services to terminate sessions).
- Okta supports **Single Logout (SLO)** via SAML.

18. What is MFA and how does Okta support it?

- MFA = Multi-Factor Authentication.
- Okta supports TOTP apps, SMS, Push, Yubikey, WebAuthn.

🛠️ Coding / Integration-Based Questions

19. Describe how to use Okta's SDK or API to authenticate users in a web app.

- Using Okta Auth SDK or OIDC client.
- Initiate auth flow, handle callback, decode JWT, create session.

20. How do you validate an ID Token or Access Token issued by Okta?

- Check signature (using Okta's public keys / JWKS endpoint).
- Verify claims (iss, aud, exp, etc.)

21. **Difference: SAML vs OAuth2 vs OIDC**

Feature	SAML	OAuth 2.0	OpenID Connect (OIDC)
Purpose	Authentication	Authorization	Authentication + Authorization
Token Format	XML	JSON (Bearer Token)	JWT (ID Token)
Common Use	Enterprise SSO (Web apps)	API access delegation	Modern login (mobile/web apps)

---

22. How would you allow both Okta SSO and local logins in a Drupal app?

Allowing **both Okta SSO and local (Drupal native)** logins in a Drupal app is a common requirement for hybrid authentication systems—especially during transitions to SSO or when internal/admin users need to bypass external IdPs.

✅ Goal: Support dual login:

- **Okta SSO** for general users (via SAML or OpenID Connect)
- **Drupal local login** (username/password) for admin or fallback users

---

🛠️ Approach Overview

Option 1: Use Conditional Routing (Recommended)

Let users choose between:

- **SSO Login (Okta)**
- **Local Drupal Login**

Option 2: Auto-redirect to SSO, with exception paths

Redirect anonymous users to Okta **except** when visiting the native login page (e.g., /user/login).

✅ Step-by-Step Implementation (Generic for SAML or OIDC)

1. Install and Configure Okta SSO Module

Depending on protocol:

- For **SAML**: Use simplesamlphp_auth
- For **OIDC**: Use openid_connect

  🔐 **Ensure module doesn't force auto-login unless triggered manually** or conditionally.

---

2. Add Custom Login Links

Modify the default Drupal login page (/user/login) to show:

<a href="/sso/login">Login with Okta</a>

And below:

<form>Drupal username/password login form</form>

You can customize this page using:

- hook_form_alter()
- A custom block on /user/login
- Theme template override for user-login.html.twig

---

3. Disable Auto-Redirect to SSO (If Applicable)

If using a module that automatically redirects all unauthenticated users to Okta (like some SAML setups), **disable** that redirect or make it conditional:

Example: In settings.php or a custom module:

```
if (!\Drupal::currentUser()->isAuthenticated()) {
  $current_path = \Drupal::service('path.current')->getPath();
  if ($current_path !== '/user/login') {
    drupal_goto('/sso/login');
  }
}
```

OR better, use hook_init() or event_subscriber to apply the logic conditionally.

---

4. Restrict Okta SSO to Specific Roles or Paths (Optional)

Some modules like openid_connect allow you to:

- Restrict auto-creation of users
- Map users to specific roles
- Allow SSO login for specific user roles only

---

5. Protect Admin Access (Best Practice)

Allow /user/login for:

- Admins
- Developers (e.g., during SSO outage)

Optional:

- Add IP whitelisting or 2FA to local login
- Use Drupal's role and permissions system to control access

🧪 Example Scenario

User Type	Login Method	Result
Employee	Clicks "Login with Okta"	Authenticated via Okta SSO
Admin	Goes to /user/login	Uses Drupal credentials
Anonymous user	Visits site	Stays anonymous or clicks SSO

✅ Summary

Feature	How to Achieve
Dual login option	Show SSO and local login links
SSO login via Okta	/sso/login (OIDC) or SAML path
Local login preserved	Allow /user/login
Auto-redirect to SSO	Optional, but disable on login page
User provisioning	Configure SSO module (e.g., auto-create)
Access control	Use Drupal roles + SSO group mappings

💡 Bonus Tip: Add Custom Login Route (Optional)

Create a route like /login with a controller or block that provides both login methods in one place.

Would you like sample code for the login page customization or conditional redirection logic?